Threat Model and Secure Configuration

EdVyro Cyber Security Internship — Task 1

Working document
Example application: Login Web Application

This document contains an example STRIDE threat analysis, illustrative risk register, and a prioritized hardening checklist. Adjust it to match the actual application and the diagram you created before submission.

Step 1 — Threat Model Diagram

Create/export your diagram from diagrams.net as a PNG and keep the editable .drawio source file too. The diagram should show the user/browser, web application/server, database, applicable external dependencies, data-flow arrows, and trust boundaries.

Diagram file to add: threat-model.png (plus the original .drawio file).

Step 2 — STRIDE Threat Analysis

Application: Login Web Application

Objective: Identify potential threats affecting the user, web application, database, and external email service.

STRIDE category	Potential threat	Possible impact
Spoofing	An attacker uses stolen login credentials.	Unauthorized account access.
Tampering	An attacker modifies user data without authorization.	Data integrity loss.
Repudiation	Insufficient audit logs make user actions difficult to trace.	Accountability and investigation issues.
Information Disclosure	Personal information is exposed to unauthorized users.	Privacy/confidentiality loss.
Denial of Service	Excessive requests overwhelm the login server.	Service interruption.
Elevation of Privilege	A normal user gains unauthorized administrator access.	Unauthorized privileged actions.

Step 3 — Risk Ranking

Scoring: Likelihood 1 = Low, 2 = Medium, 3 = High. Impact 1 = Low, 2 = Medium, 3 = High. Risk Score = Likelihood × Impact. Risk levels: 1–2 Low, 3–4 Medium, 6–9 High.

Threat	Likelihood	Impact	Score	Level
Spoofing	3 (High)	3 (High)	9	High
Tampering	2 (Medium)	3 (High)	6	High
Repudiation	2 (Medium)	2 (Medium)	4	Medium
Information Disclosure	2 (Medium)	3 (High)	6	High
Denial of Service	2 (Medium)	3 (High)	6	High
Elevation of Privilege	2 (Medium)	3 (High)	6	High

These scores are illustrative estimates for a sample login application, not verified findings. Update them if you learn more about the actual system.

Step 4 — Prioritized Hardening Checklist

Use this as a starting checklist for the example login application. Mark an item complete only after you have documented how it is addressed; do not claim controls were tested unless you tested them.

Priority	Recommended control	Verification idea
High	Require multi-factor authentication where supported, and protect against repeated failed logins.	Review authentication settings and test rate limits in an authorized test environment.
High	Use parameterized database queries and validate input server-side.	Review code or configuration for safe query handling.
High	Enforce authorization checks on every protected route and admin action.	Test with a normal account that admin-only actions are denied.
High	Use HTTPS and secure session-cookie settings.	Check HTTPS redirection and Secure, HttpOnly, and SameSite cookie attributes.
High	Restrict database access and protect stored credentials with a suitable password-hashing function.	Review database permissions and password-storage design; never store plaintext passwords.
Medium	Avoid exposing sensitive personal data in errors or responses.	Review error messages and responses for unnecessary sensitive details.
Medium	Record authentication and security-relevant events without logging passwords or secrets.	Review audit logs for useful timestamps and event details.
Medium	Apply rate limiting and monitoring to help detect abusive traffic.	Review limits and alerts in a controlled test.
Medium	Secure the external email/OTP integration and protect tokens or reset links.	Review token expiry, single-use behavior, and service credentials.

Conclusion

The STRIDE model helps identify potential threats, the risk register prioritizes them, and the hardening checklist proposes defensive controls. This is an example-based working document; tailor it to your actual diagram and the internship guide before submission.

Suggested repository files: README.md, threat-model.png, source-diagram.drawio, stride-threat-analysis.txt or .md, risk-register.csv or .md, hardening-checklist.md, and this PDF.